

AUTOMOTIVE PENTEST REPORT

AutoCyberAudit — Kyvra Security Platform

Version 3.0.0

VIN	WBA3A5G59ENP26705
Auditeur	Gab — Kyvra Security
Organisation	Kyvra
Périmètre	BMW X5 WBA3A5G59ENP26705 — Lab Audit
Date	29/06/2026 07:11 UTC
Session ID	a1b2c3d4e5f6
Outil	AutoCyberAudit v3.0.0

Résumé exécutif

Sévérité	Nombre
CRITICAL	5
HIGH	2
MEDIUM	3

Informations Véhicule

VIN	WBA3A5G59ENP26705
Protocole	ISO 15765-4 CAN
RPM	820 tr/min
DTC actifs	2 (P0128, U0101)

Tableau des Vulnérabilités

#	Sévérité	Module	Type	Description
1		CAN Bus	CAN_SENSITIVE_ID	ID 0x143 (Brake Control) — data: 0a ff 00 01
2		WiFi	WIFI_WEAK_CRYPTO	Hotspot MyCarHotspot sans WPA2
3		API Telematics	API_IDOR_VIN	IDOR VIN — accès données véhicule tiers
4		Firmware / OTA	FIRMWARE_PRIVATE_KEY	Clé privée RSA détectée @ offset 0x2A40
5		CAN Bus	CAN_DOS_PATTERN	ID 0x7DF : 8421 frames/30s — flood potentiel
6		OBD-II/UDS	UDS_EXTENDED_SESSION_OPEN	Session étendue acceptée sans SecurityAccess
7		Bluetooth	BLE_SERIAL_PORT_EXPOSED	Profil SPP exposé sans chiffrement
8	MEDIUM	OBD-II/UDS	OBD_VIN_EXPOSED	VIN récupéré sans authentification
9	MEDIUM	API Telematics	API_MISSING_HEADERS	HSTS, CSP, X-Frame-Options absents
10	MEDIUM	Bluetooth	BLE_TPMS_VISIBLE	TPMS Continental visible — tracking possible

Détail des Vulnérabilités

Module : CAN Bus

[CRITICAL] CAN_SENSITIVE_ID

Description	ID 0x143 (Brake Control) — data: 0a ff 00 01
Recommandation	Filtrer via CAN gateway sécurisé
Horodatage	2026-06-29T12:00:00Z

[CRITICAL] CAN_DOS_PATTERN

Description	ID 0x7DF : 8421 frames/30s — flood potentiel
Recommandation	Rate-limiting et anomaly detection
Horodatage	2026-06-29T12:07:00Z
can_id	0x7df

Module : WiFi

[CRITICAL] WIFI_WEAK_CRYPTO

Description	Hotspot MyCarHotspot sans WPA2
Recommandation	Configurer WPA3 minimum
Horodatage	2026-06-29T12:03:00Z
ssid	MyCarHotspot

Module : API Telematics

[CRITICAL] API_IDOR_VIN

Description	IDOR VIN — accès données véhicule tiers
Recommandation	Valider propriété VIN côté serveur
Horodatage	2026-06-29T12:04:00Z
path	/api/v1/vehicles/WBA...

[MEDIUM] API_MISSING_HEADERS

Description	HSTS, CSP, X-Frame-Options absents
Recommandation	Ajouter headers HTTP sur le reverse proxy
Horodatage	2026-06-29T12:08:00Z

Module : Firmware / OTA

[CRITICAL] FIRMWARE_PRIVATE_KEY

Description	Clé privée RSA détectée @ offset 0x2A40
Recommandation	Utiliser HSM/TPM pour les clés privées
Horodatage	2026-06-29T12:05:00Z
offset	0x2A40

Module : OBD-II/UDS

[HIGH] UDS_EXTENDED_SESSION_OPEN

Description	Session étendue acceptée sans SecurityAccess
Recommandation	Implémenter SID 0x27 avant session étendue
Horodatage	2026-06-29T12:01:00Z

[MEDIUM] OBD_VIN_EXPOSED

Description	VIN récupéré sans authentification
Recommandation	Journaliser les accès VIN
Horodatage	2026-06-29T12:06:00Z

Module : Bluetooth

[HIGH] BLE_SERIAL_PORT_EXPOSED

Description	Profil SPP exposé sans chiffrement
Recommandation	Désactiver SPP ou chiffrer le canal RFCOMM
Horodatage	2026-06-29T12:02:00Z

[MEDIUM] BLE_TPMS_VISIBLE

Description	TPMS Continental visible — tracking possible
Recommandation	Activer rotation MAC BLE
Horodatage	2026-06-29T12:09:00Z
address	EE:FF:00:11:22:33